ZYROO INTERNSHIP PROGRAM

Week 5 | Privilege Escalation

Cybersecurity Internship

Task: Escalate Privileges on a Compromised Target
Target: Metasploitable2 (192.168.10.4)
Attacker Host: Kali Linux (192.168.10.11)
Tools Used: Nmap, Metasploit Framework, LinPEAS, Exploit-DB
GitHub Repository: https://github.com/Aans9988/Zyro-cyber-security-week-5.git

1. Re-establish Access

Following on from Week 4, connectivity to the Metasploitable2 lab target (192.168.10.4) was re-confirmed before continuing enumeration. A ping test verified reachability, and a full TCP port/service scan with Nmap was re-run to reconfirm the exposed attack surface prior to escalation work.

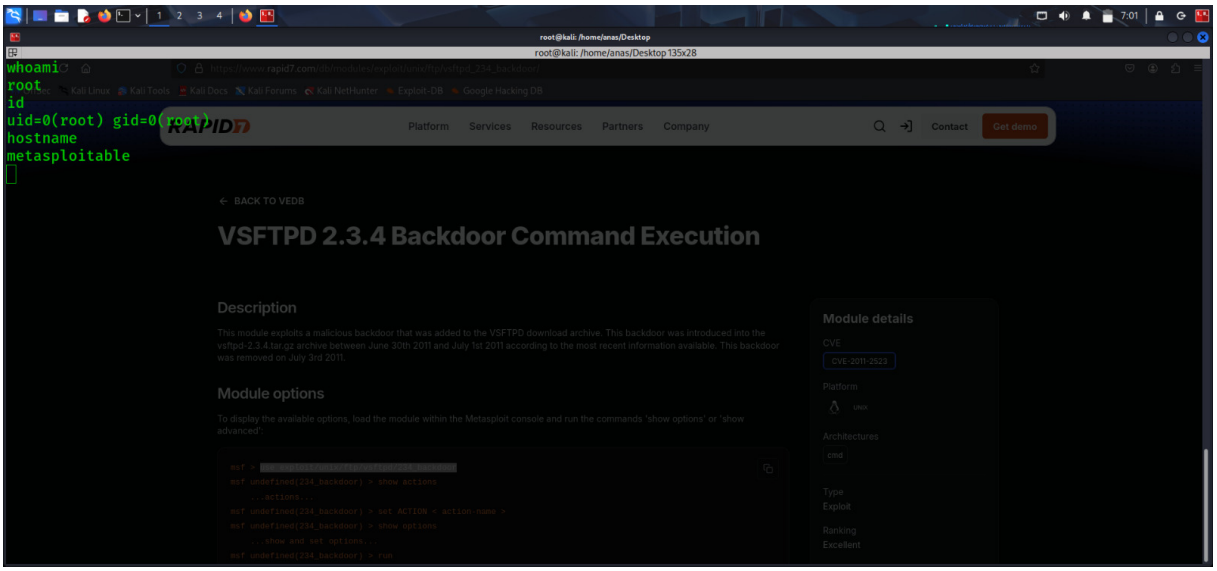


Figure 1. Connectivity check (ping) and full Nmap service scan (-sV -p-) against 192.168.10.4.



Figure 2. Nmap scan results continued — full list of open ports and service versions on the target.

2. Enumerate the System

The Nmap service scan was reviewed to identify outdated or vulnerable service versions running on the target. One entry stood out immediately: port 21/tcp was running **vsFTPd 2.3.4**, a version of the FTP daemon publicly known to contain a malicious backdoor planted in its source archive between June 30 and July 1, 2011 (CVE-2011-2523). This was selected as the primary enumeration finding to pursue for escalation, since it is a known, high-reliability root-level vector rather than a low-privilege foothold requiring further local enumeration (e.g. LinPEAS/SUID checks).

Metasploit's module database was searched for a matching exploit for the identified service version.

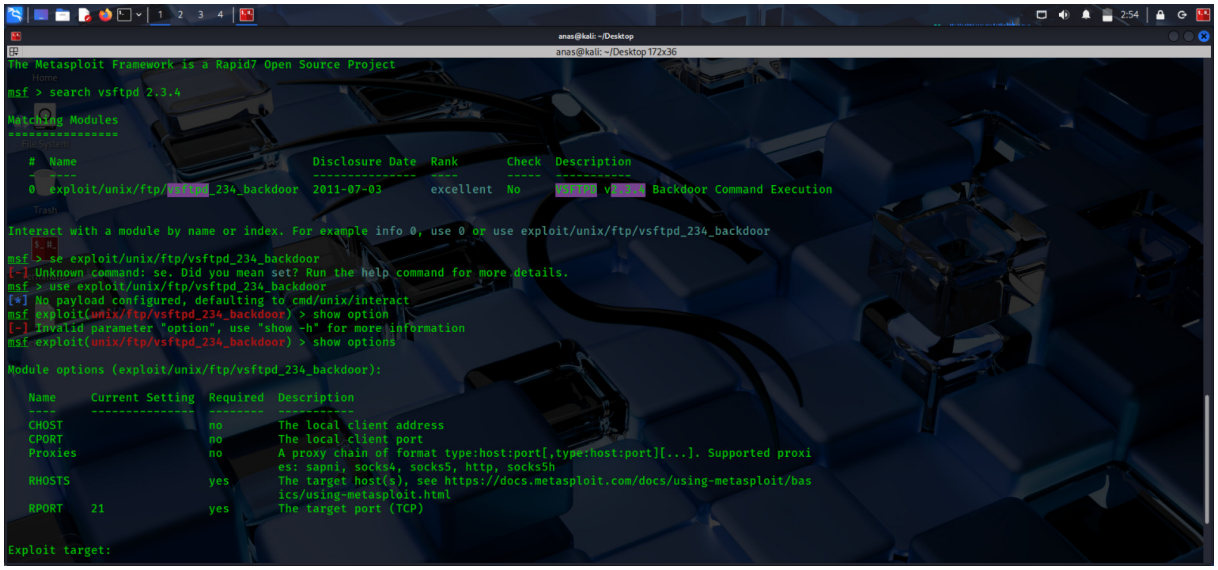


Figure 3. Searching Metasploit for the vsftpd 2.3.4 service version and locating the matching exploit module.

3. Identify an Escalation Path

Vector: exploit/unix/ftp/vsftpd_234_backdoor
Why it works: The vsftpd 2.3.4 archive distributed on the official download mirror was compromised by an attacker and modified to include a hidden backdoor. When a username containing a smiley face sequence (e.g. ending in ":)") is sent to the FTP service, the backdoor code spawns a listening shell on TCP port 6200 with **root privileges** — no authentication or credentials are required. This is a supply-chain compromise / malicious-package misconfiguration, not a local privilege escalation bug, so successful exploitation grants root access directly rather than escalating from an existing low-privileged shell.

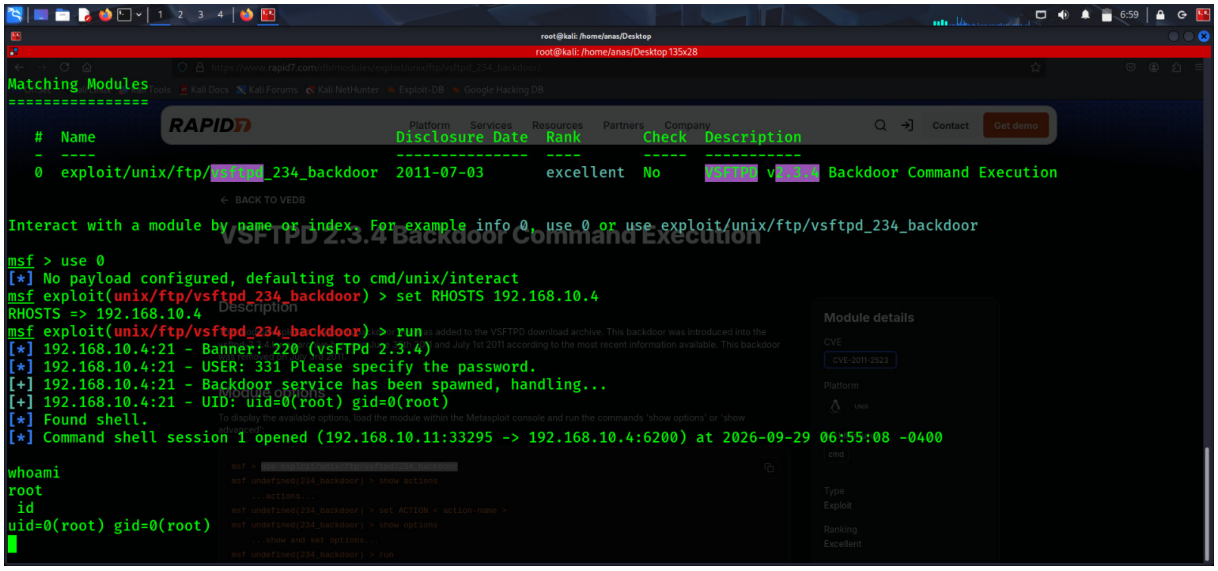


Figure 4. Exploit-DB / Rapid7 module reference page for VSFTPD 2.3.4 Backdoor Command Execution (CVE-2011-2523), confirming the vulnerability details.

4. Execute the Escalation

The Metasploit module was loaded and configured with the target IP address, then executed.



Figure 5. Configuring the exploit module — setting RHOSTS to 192.168.10.4 and reviewing module options.

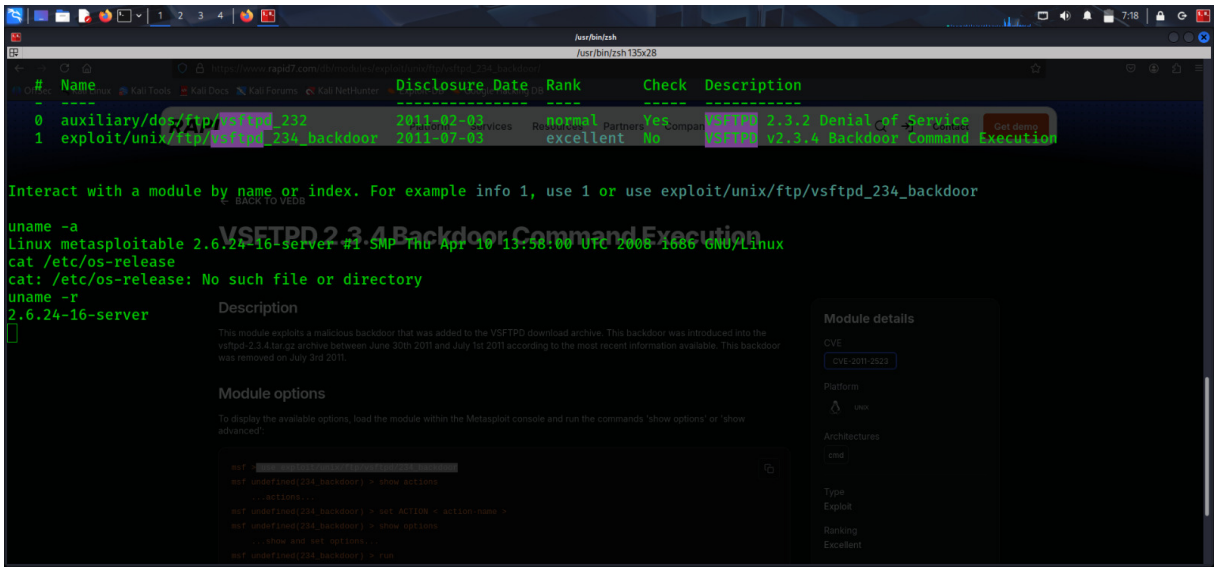


Figure 6. Running the exploit — the backdoor service is triggered, spawning a root command shell session on port 6200.

Confirming Elevated Privileges

Once the shell session was opened, the privilege level was confirmed directly on the target using **whoami**, **id**, and **hostname**.

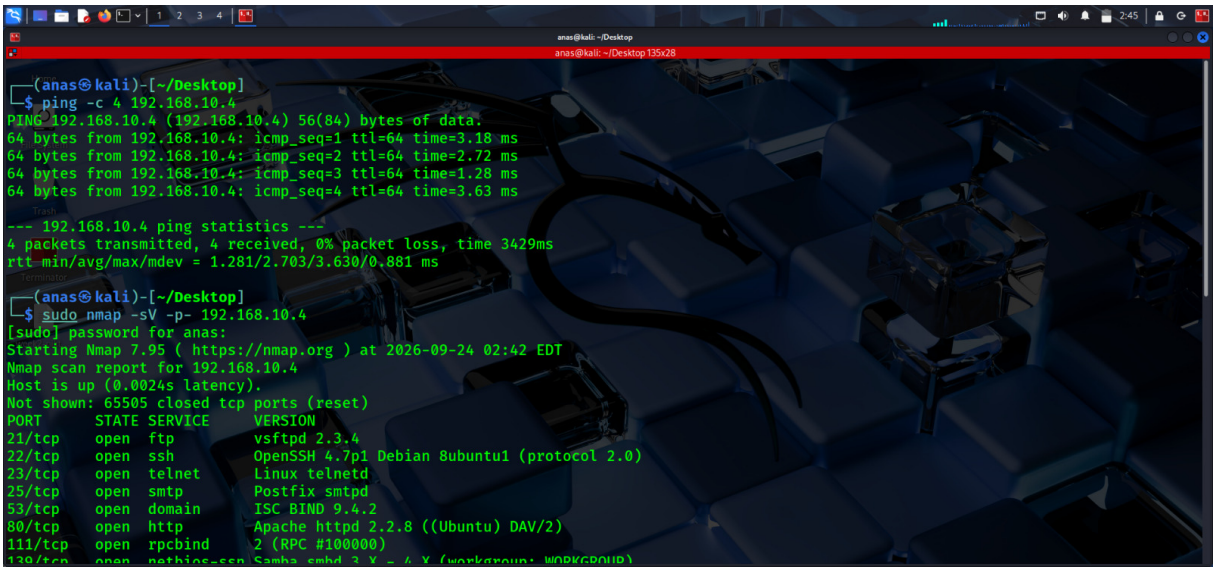


Figure 7. Post-exploitation confirmation — whoami returns 'root', id shows uid=0(root) gid=0(root), and hostname confirms the target is 'metasploitable'.

System Information Gathered Post-Compromise

Additional commands were run inside the root shell to fingerprint the compromised host and confirm the outdated, unpatched kernel that reflects the overall poor patch hygiene of the target.

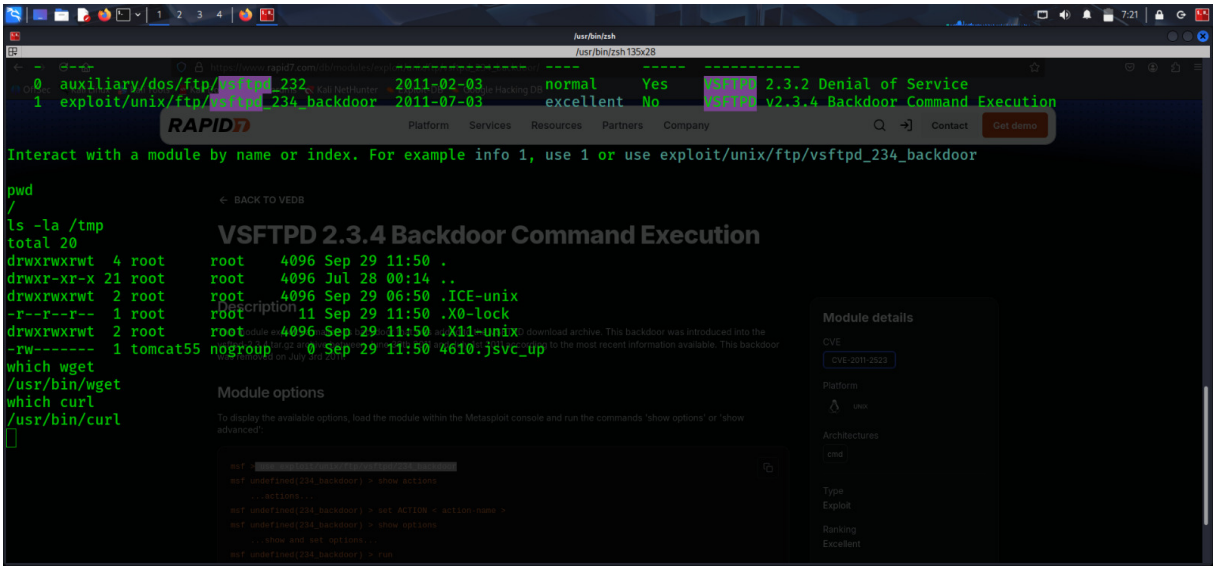


Figure 8. Kernel/OS fingerprinting from the root shell — uname -a reveals Linux kernel 2.6.24-16-server (2008), confirming a severely outdated, unpatched system.

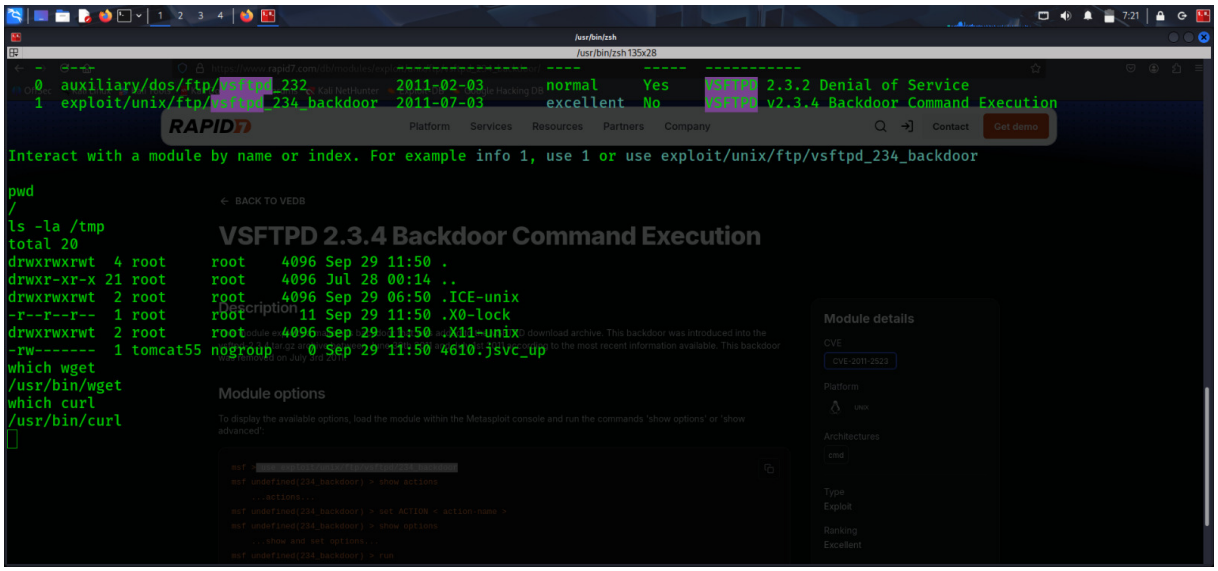


Figure 9. Further root-shell enumeration — file permissions in /tmp and confirmation that wget/curl are available on the compromised host for follow-on actions.

Post-Exploitation Enumeration (LinPEAS)

With a root shell already established via the vsftpd backdoor, LinPEAS was transferred to the target and executed to comprehensively enumerate the host, both to validate the privilege level and to identify additional sensitive data exposed as a result of the compromise.

Transferring LinPEAS to the Target

A Python HTTP server was started on the Kali attack host to serve the LinPEAS script, which was then downloaded onto the target using wget from within the root shell.

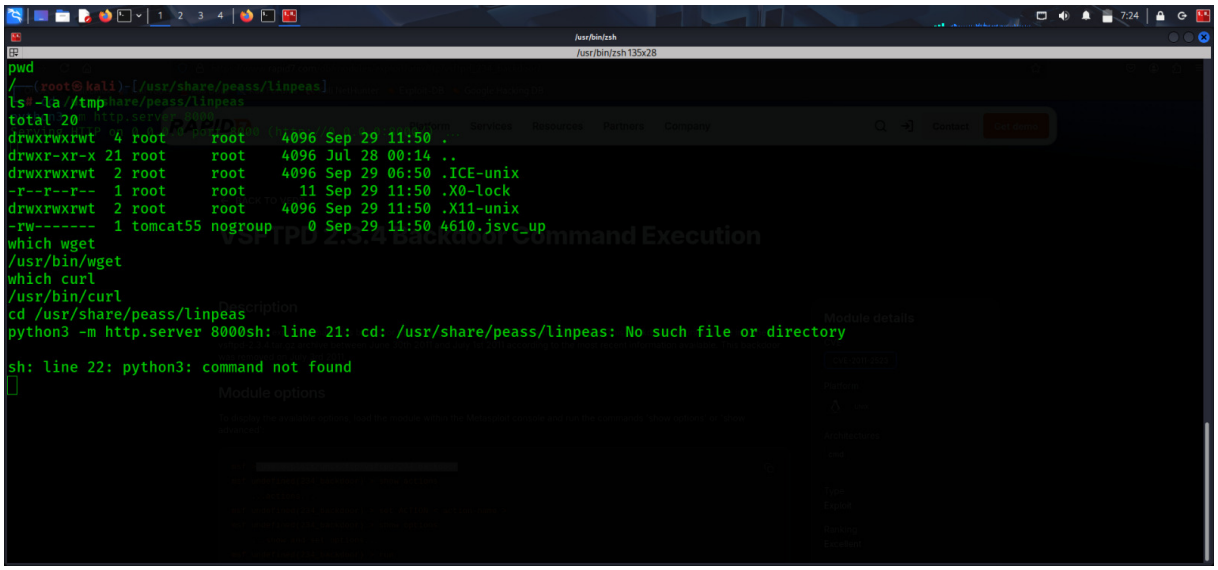


Figure 10. Initial attempt to retrieve LinPEAS from the target shell — first path/command errors before falling back to /tmp.

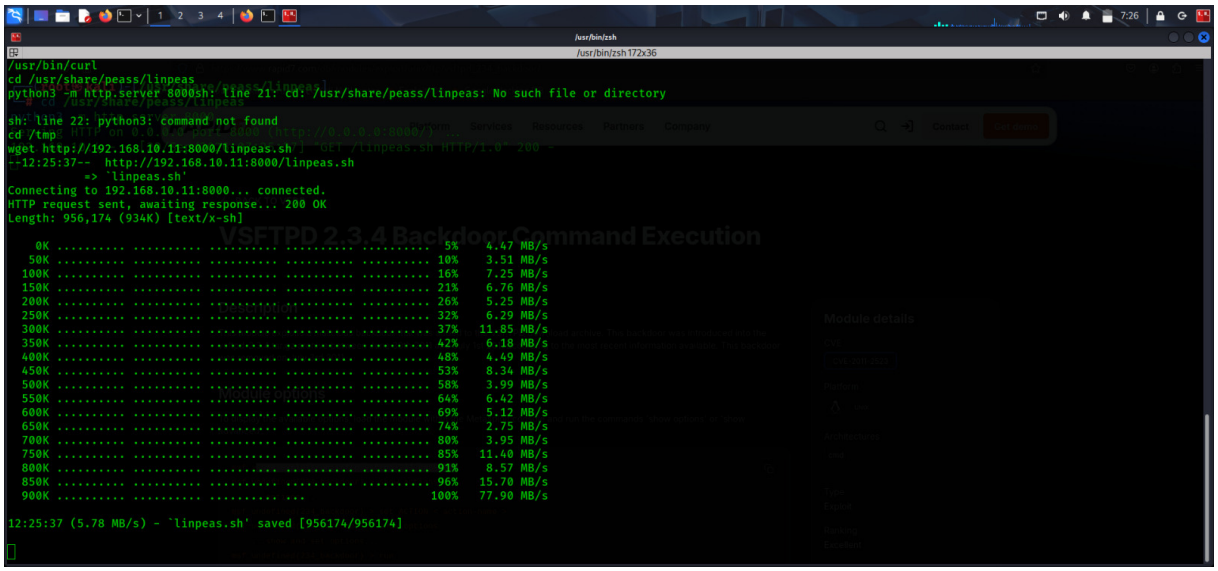


Figure 11. LinPEAS successfully downloaded to the target via wget from the Kali-hosted Python HTTP server.

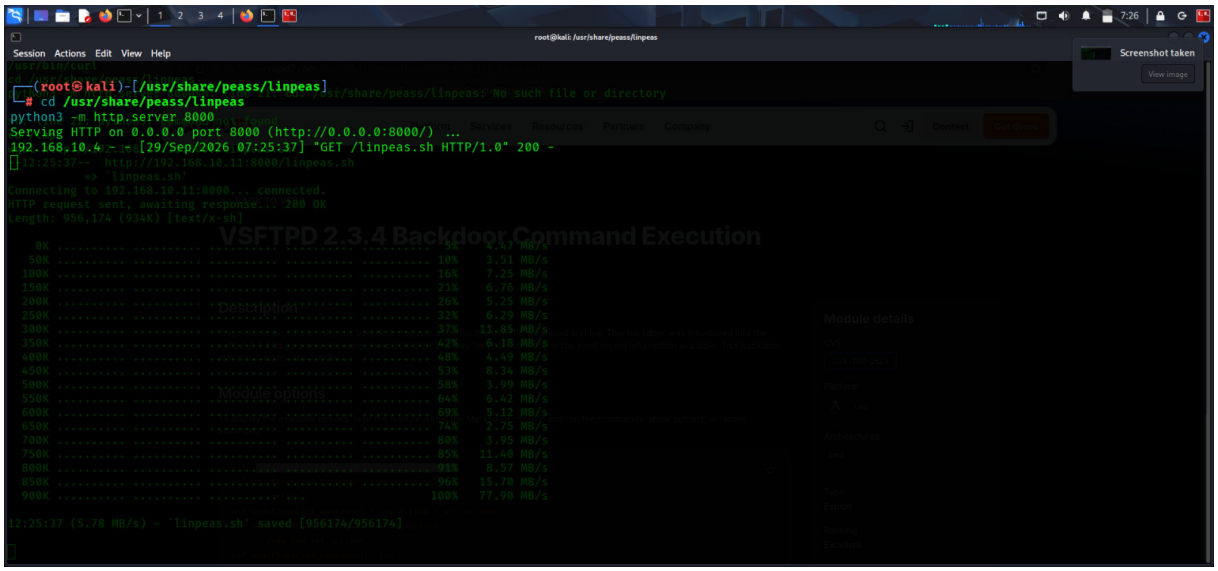


Figure 12. Kali attack host side — Python HTTP server log confirming the target requested and retrieved linpeas.sh.

Running LinPEAS

LinPEAS was executed on the target. The script's own privilege-escalation checklist immediately flagged **"YOU ARE ALREADY ROOT!!!"**, independently confirming the root access gained through the vsftpd backdoor exploit, and reported basic system information consistent with the earlier manual enumeration (kernel 2.6.24-16-server, hostname metasploitable, uid=0/gid=0).

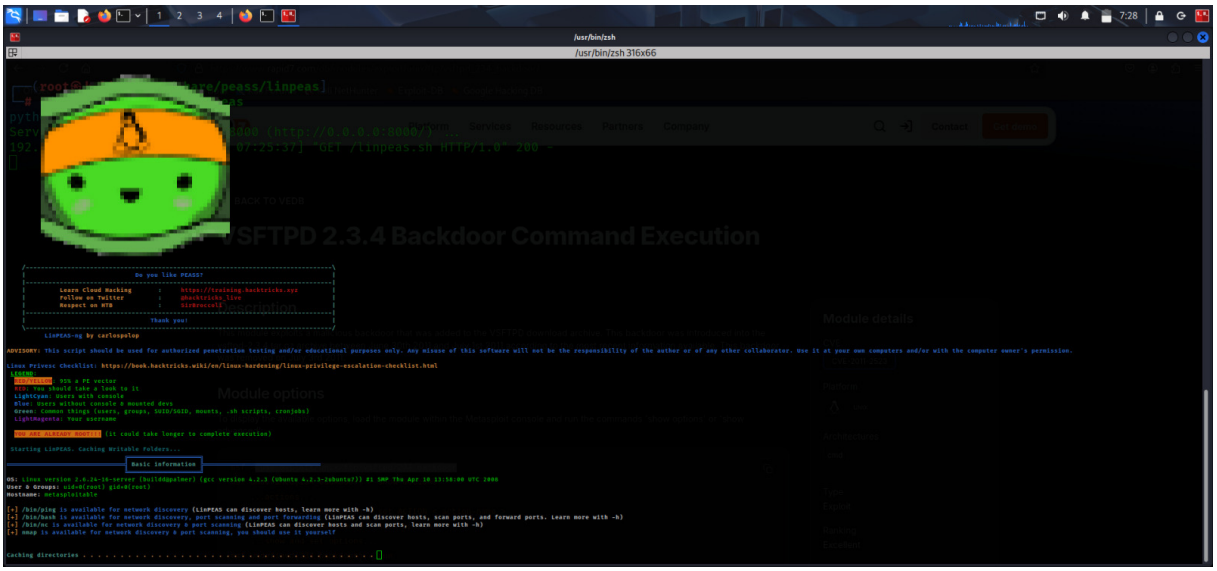


Figure 13. LinPEAS execution output confirming root privileges and displaying basic host information (OS, kernel, user, hostname).

Sensitive Data Exposed

LinPEAS' deeper file-system sweep uncovered numerous additional exposure points beyond the initial foothold, reinforcing how much a single compromised service can expose on a poorly hardened host:

• World-readable backup files under /var/backups/ and /etc/lvm/backup/, including `shadow.bak`, `passwd.bak`, and `group.bak` — historical copies of the system's password/shadow files.

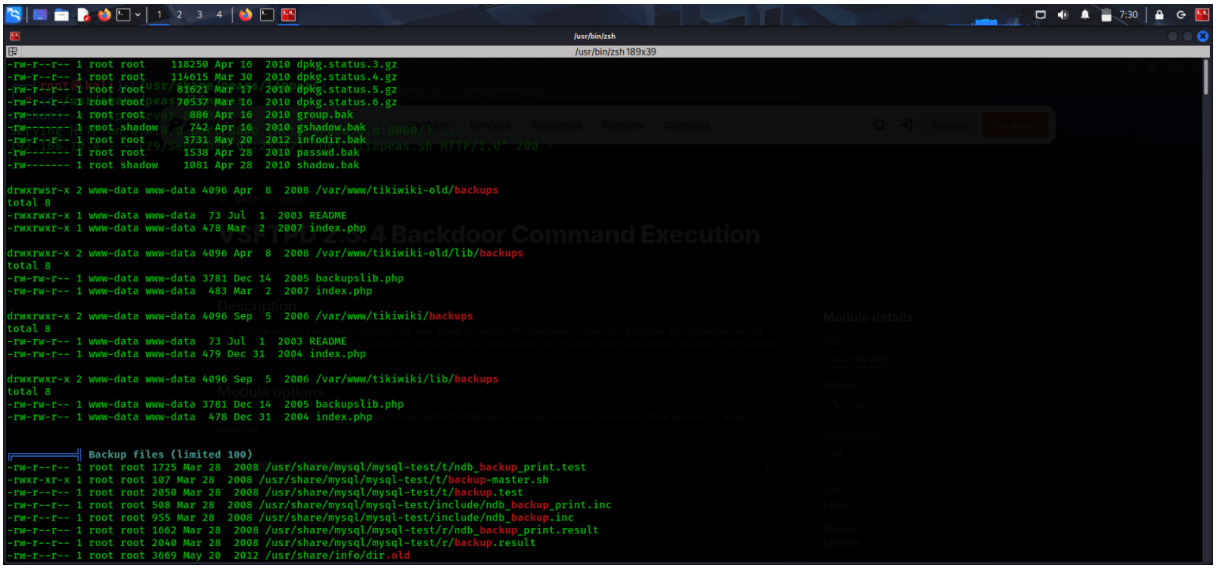


Figure 14. LinPEAS listing world-readable backup files, including shadow.bak, passwd.bak, and group.bak under /var/backups/.

• Additional backup and legacy application files across /usr/share and the TikiWiki web application directories, and a boot-time initrd backup image.

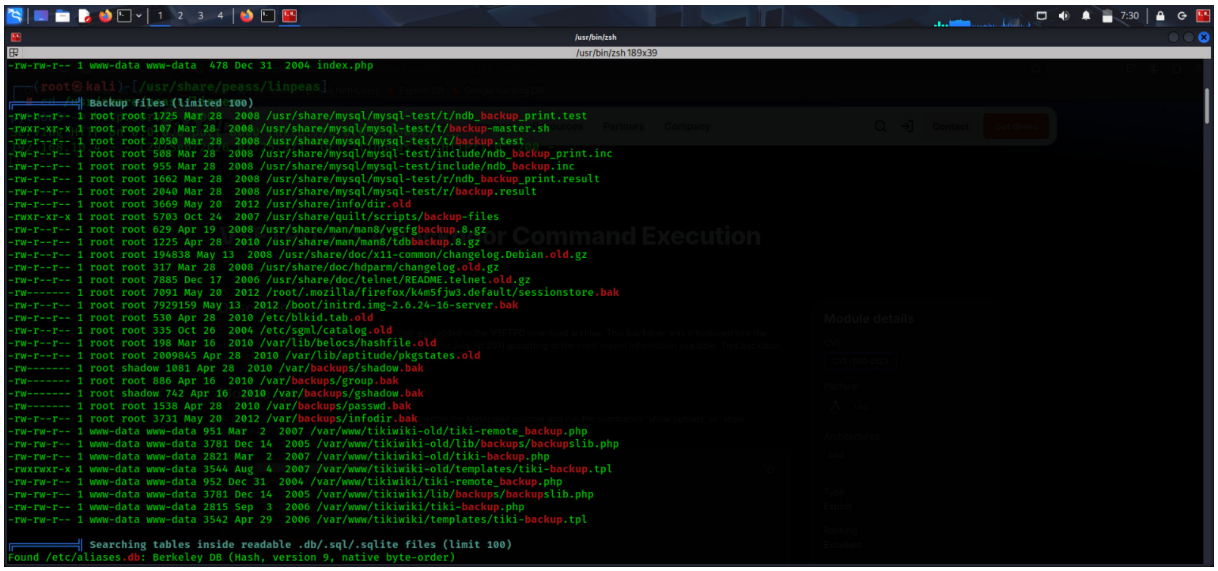


Figure 15. Further backup file discovery, including an initrd backup image and legacy TikiWiki backup scripts.

• Readable SQLite/database files on the host, including a Firefox profile database containing a `moz_logins` table with a stored, encrypted set of login credentials for twitter.com — evidence that credentials cached in a browser profile on this box would also be exposed to any attacker with this level of access.

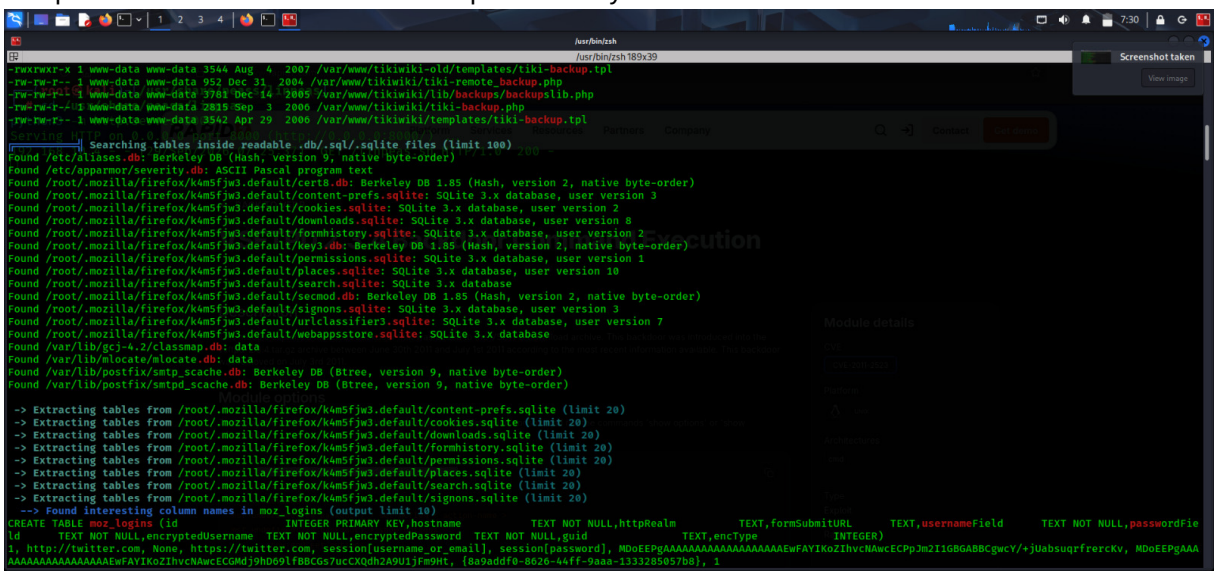


Figure 16. LinPEAS identifying readable database/SQLite files on the host, including a Firefox profile database.

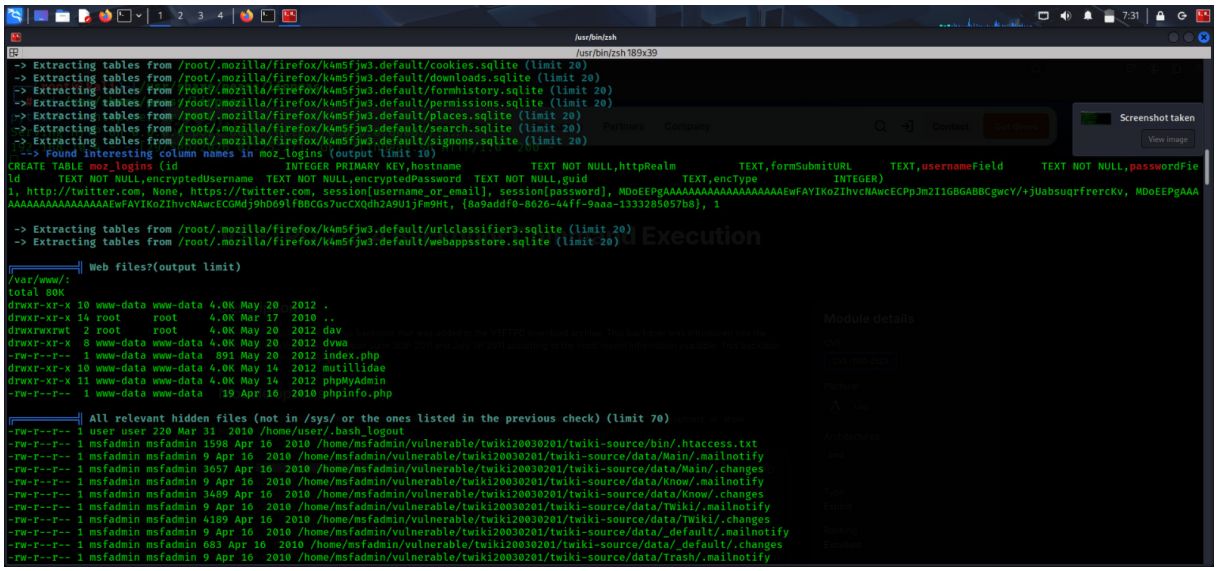


Figure 17. Extracted moz_logins table from the Firefox profile, showing a stored (encrypted) credential entry for twitter.com, plus a listing of exposed web application directories (DVWA, phpMyAdmin, Mutillidae).

• Additional world-readable files under /tmp and related temp/backup directories, and an ongoing search of shell/tool history files (e.g. .mysql_history) for embedded credentials.

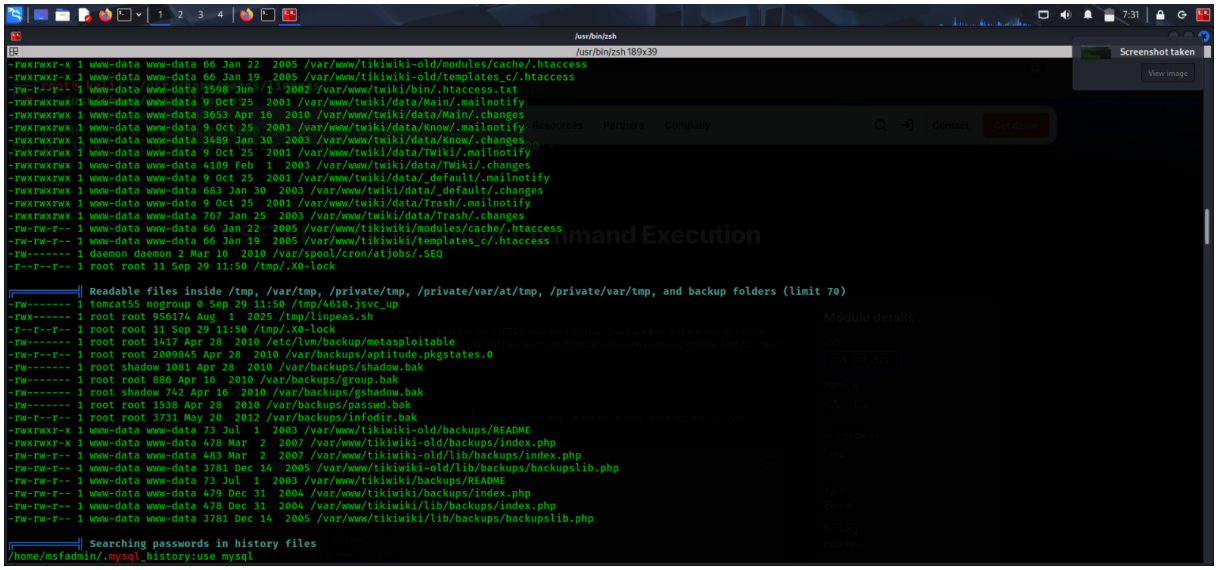


Figure 18. LinPEAS enumerating readable files in /tmp and backup locations, and beginning a search for passwords inside history files (.mysql_history).

Environment and Configuration Enumeration

LinPEAS also dumped the full process environment and Debian installer logs on the host, confirming process ownership, the network origin of the attacking session, and configuration templates handled during the original OS install.

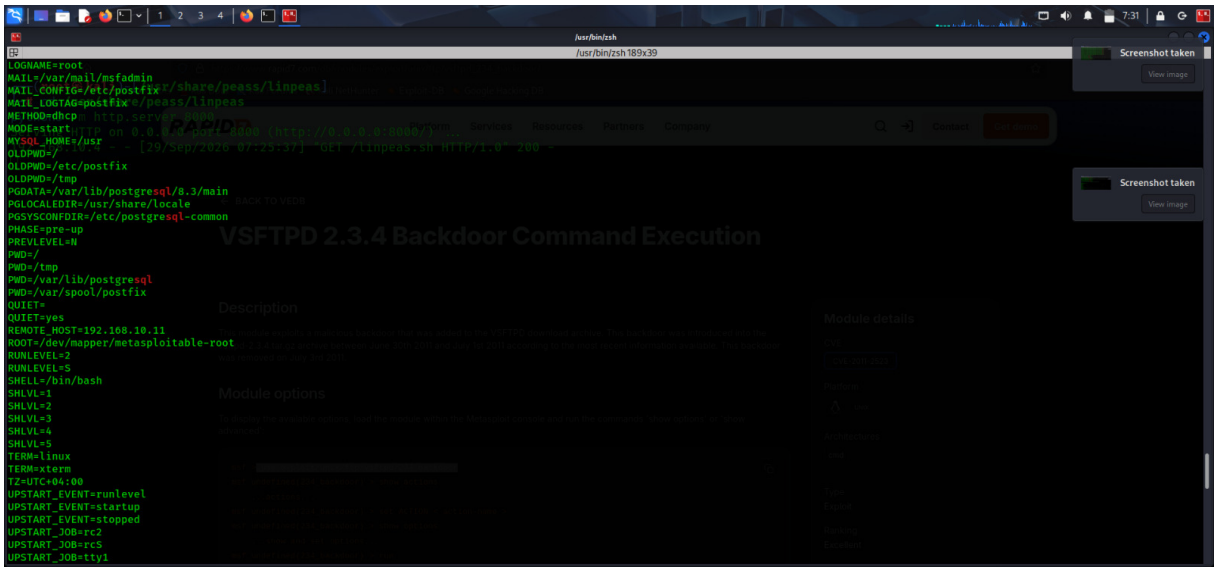


Figure 19. Environment variables captured by LinPEAS, including REMOTE_HOST=192.168.10.11 confirming the attacking host's IP.

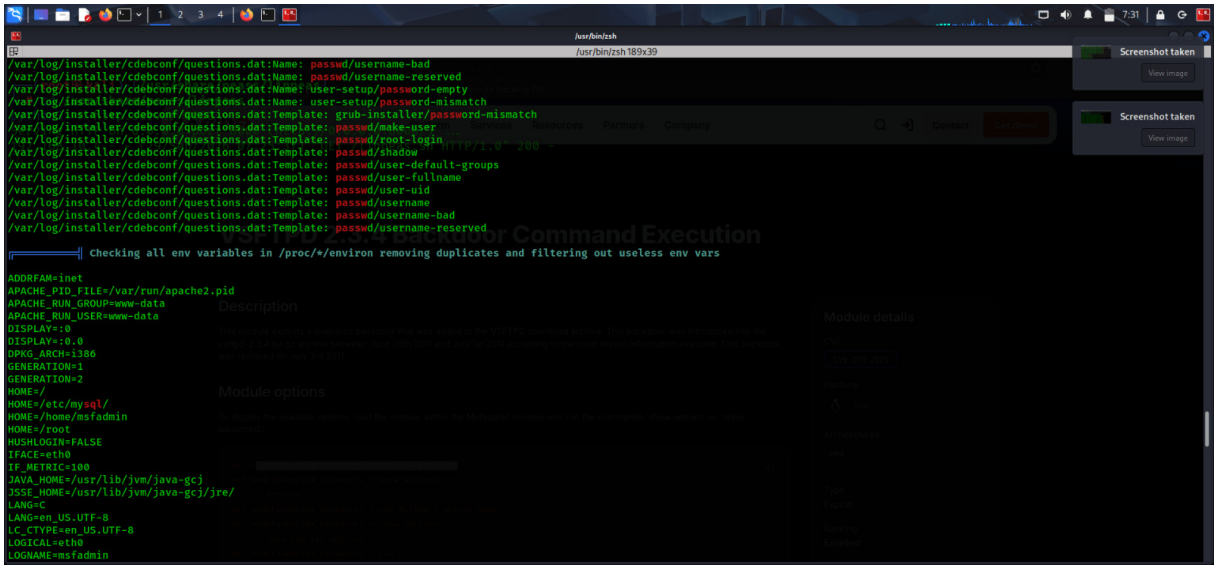


Figure 20. Continued environment variable dump and Debian installer (cdebconf) question templates referencing password/user-setup fields.

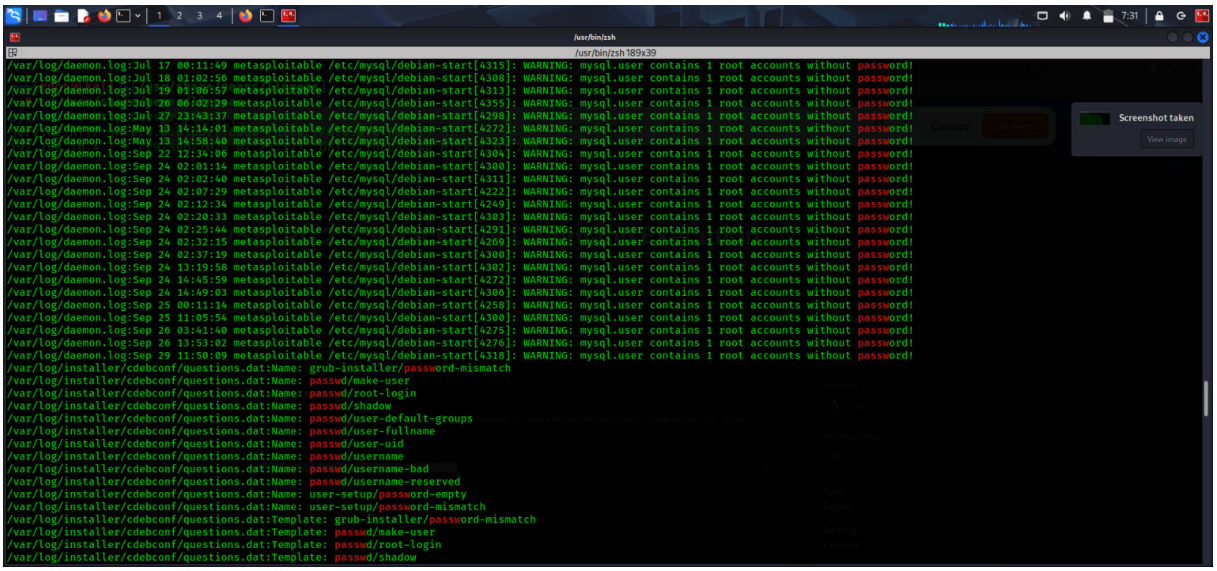


Figure 21. Further daemon.log warnings (MySQL root account without a password) and cdebconf installer templates.

Critical Finding: Plaintext Credentials in Logs

The most significant finding from this phase of enumeration was that LinPEAS's audit-log search recovered **plaintext SSH passwords** for the msfadmin account directly from `/var/log/auth.log`, alongside repeated warnings that the MySQL root account was configured with no password at all.

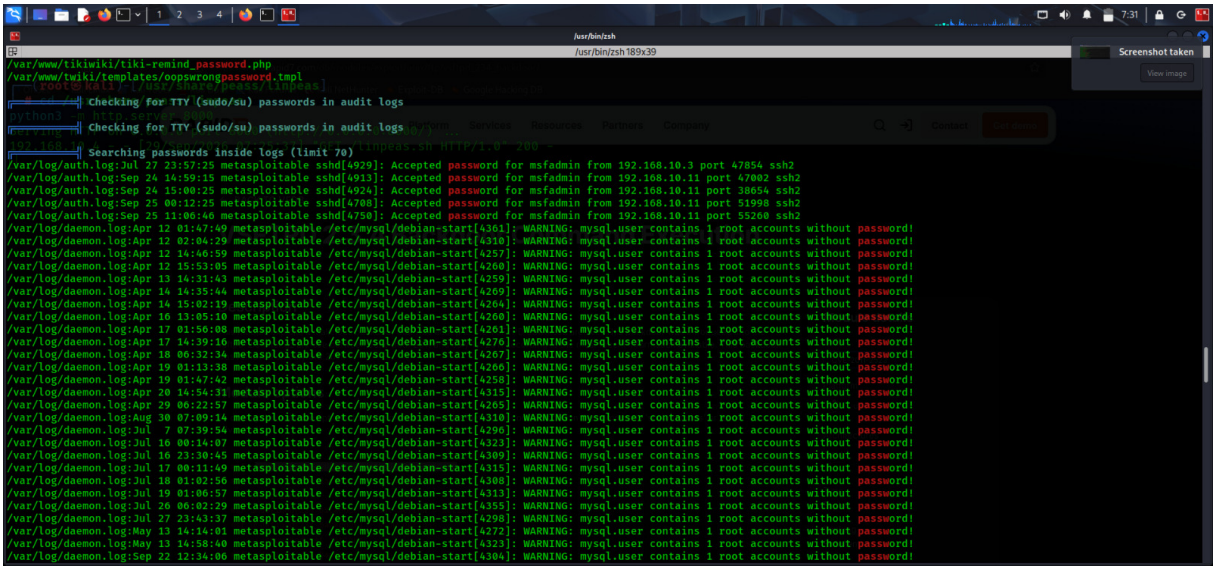
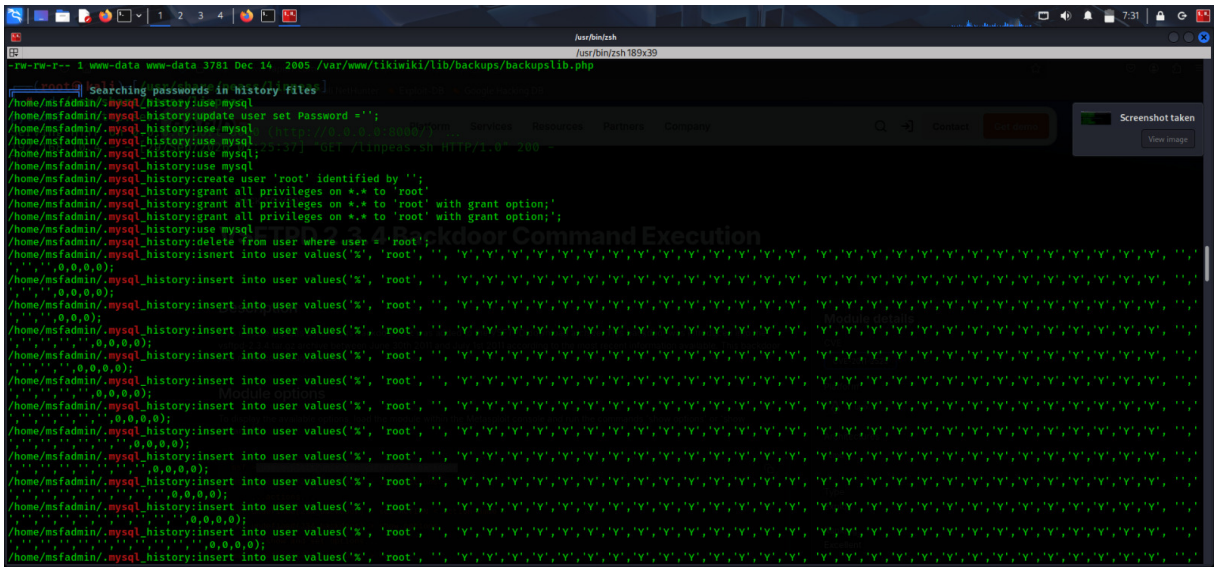


Figure 22. Critical finding — /var/log/auth.log contains plaintext accepted SSH passwords for the msfadmin account, and daemon.log repeatedly flags a passwordless MySQL root account.

Critical Finding: Command History Exposing Root Account Creation

The msfadmin user's `.mysql_history` file was also found to be readable and contained the literal SQL statements used to create the MySQL **root** account with an **empty password** and grant it full privileges — a serious historical misconfiguration now fully exposed to anyone with filesystem access.


-rw-rw-r-- 1 www-data www-data 3781 Dec 14 2005 /var/www/tikiwiki/lib/backups/backupslib.php
Searching passwords in history files
/home/msfadmin/.mysql_history:use mysql
/home/msfadmin/.mysql_history:update user set Password ='';
/home/msfadmin/.mysql_history:use mysql
/home/msfadmin/.mysql_history:use mysql
/home/msfadmin/.mysql_history:use mysql;
/home/msfadmin/.mysql_history:use mysql
/home/msfadmin/.mysql_history:create user 'root' identified by '';
/home/msfadmin/.mysql_history:grant all privileges on *.* to 'root'
/home/msfadmin/.mysql_history:grant all privileges on *.* to 'root' with grant option;'
/home/msfadmin/.mysql_history:grant all privileges on *.* to 'root' with grant option;';
/home/msfadmin/.mysql_history:use mysql
/home/msfadmin/.mysql_history:delete from user where user = 'root';
/home/msfadmin/.mysql_history:isnert into user values('%', 'root', '', 'Y','Y','Y','

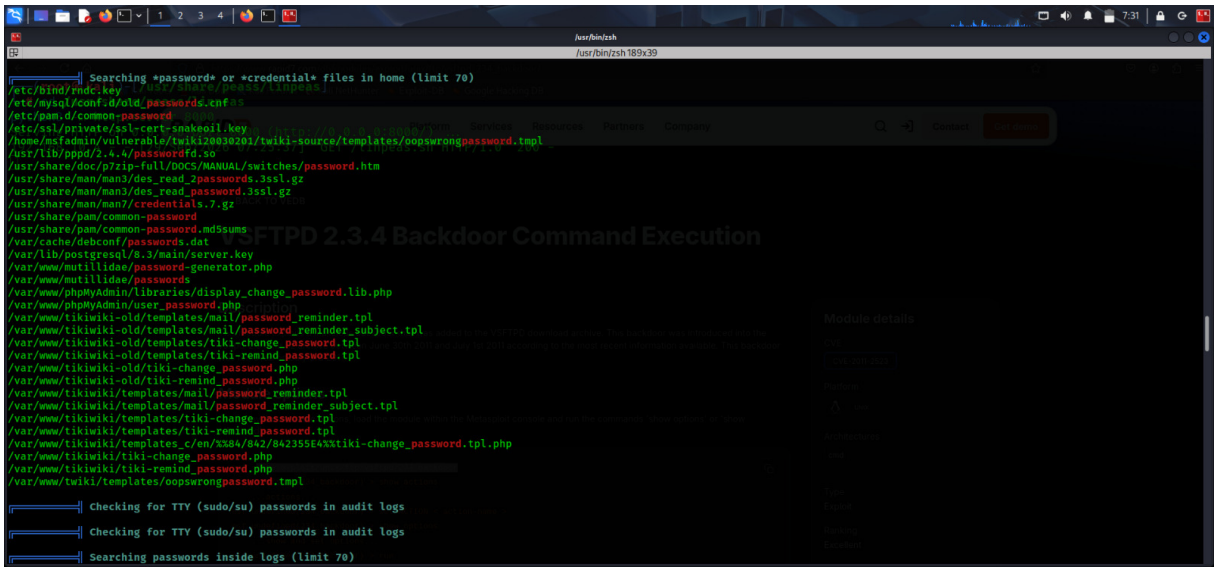


Figure 25. LinPEAS's search for files named *password* or *credential* across the filesystem — SSL private keys, PAM config, and multiple web-app (Mutillidae, phpMyAdmin, TikiWiki, TWiki) password-related files.

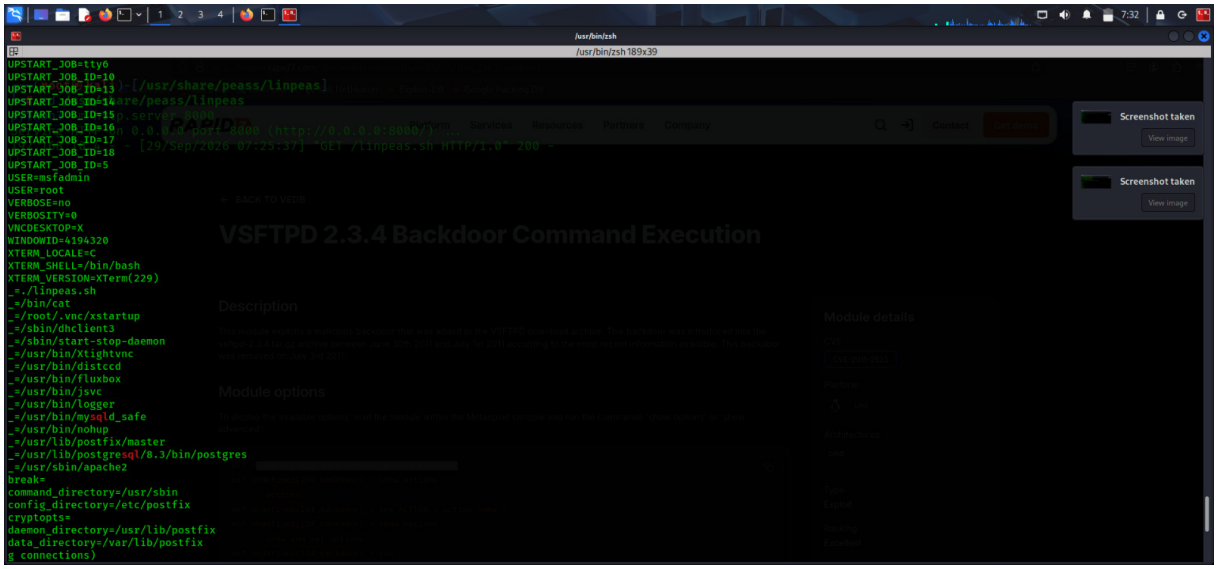


Figure 26. LinPEAS environment/UPSTART job listing and Postfix mail configuration paths gathered during the same sweep.

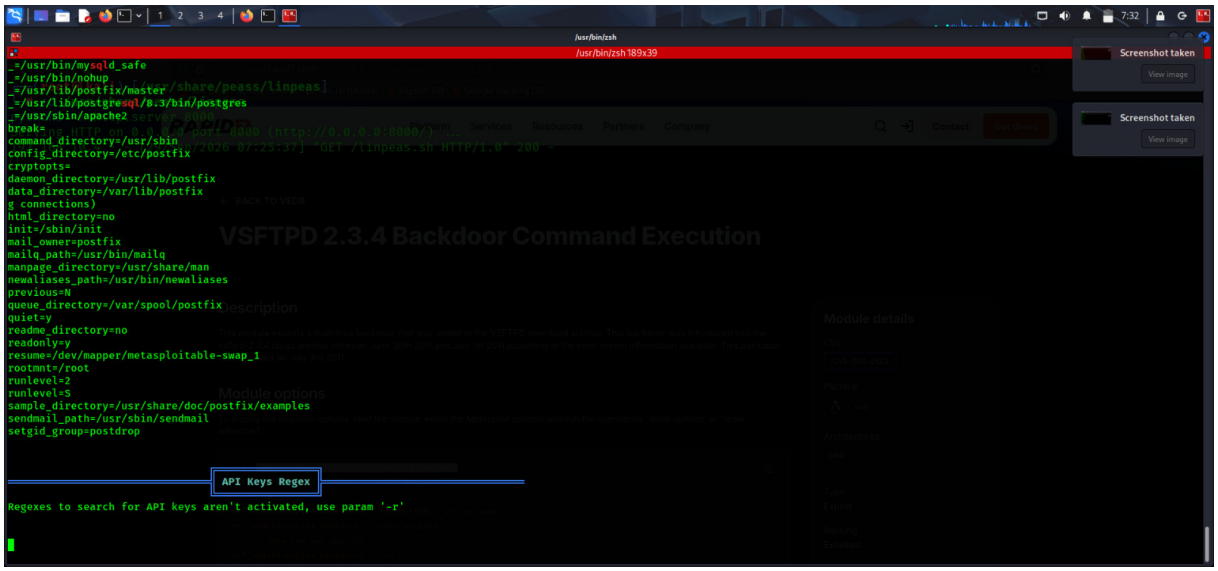


Figure 27. Continued Postfix/PostgreSQL binary and config paths; LinPEAS's API Keys Regex module noting that dedicated API-key scanning was not enabled for this run (-r flag).

Additional Local Privilege Escalation Vector: SUID Nmap (Interactive Mode)

In addition to the direct-root vsftpd backdoor exploit above, the target was also assessed from a genuine low-privilege foothold (the `msfadmin` account, uid=1000) to demonstrate the classic local privilege-escalation path the task originally called for: enumerate SUID/SGID binaries, identify a viable vector, and exploit it to reach root.

Enumeration

A manual search for SUID binaries was run with `find / -perm -4000 -type f`, and LinPEAS's own SUID/SGID/cron/writable-file checks were filtered for the same indicators.

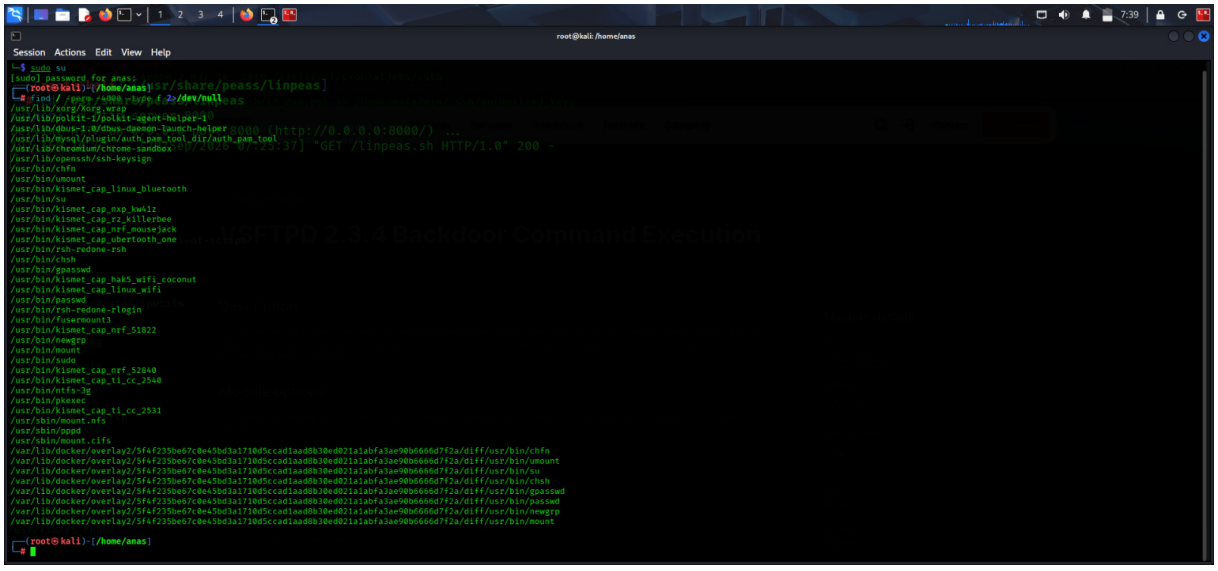


Figure 28. Manual enumeration of SUID binaries across the filesystem using find / -perm -4000 -type f.

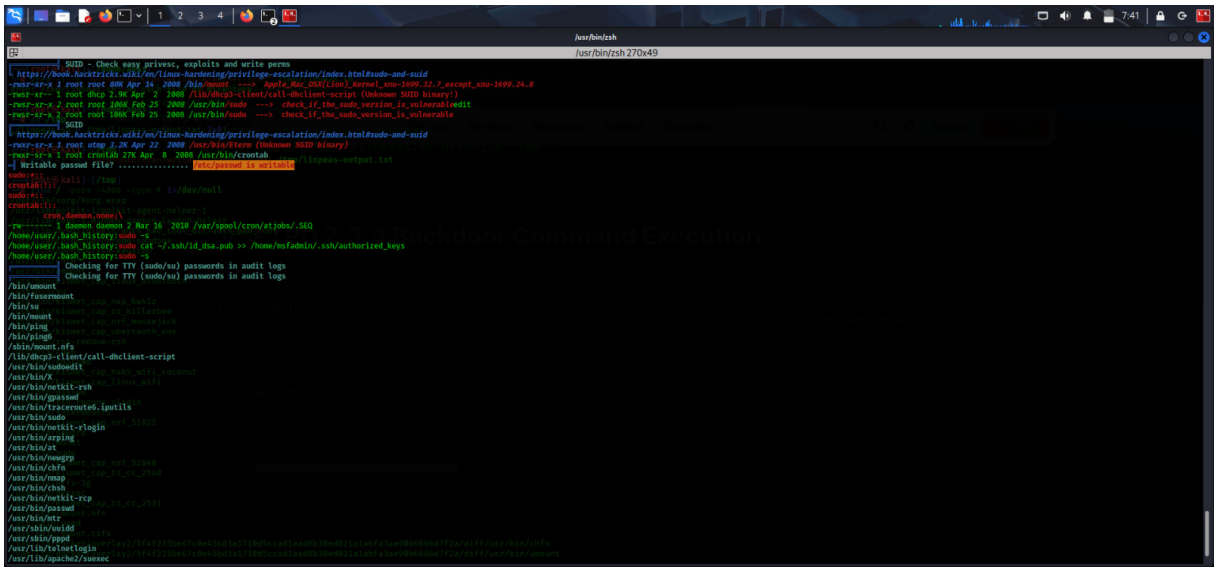


Figure 29. LinPEAS SUID/SGID findings, flagging a potentially vulnerable sudo binary version and reporting /etc/passwd as writable.

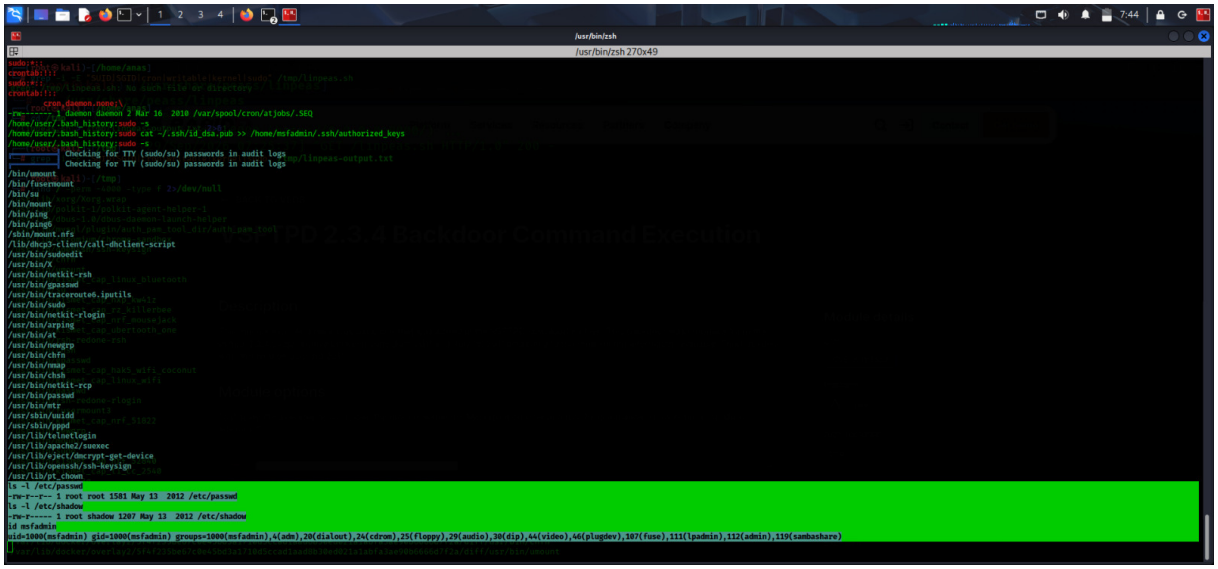


Figure 30. Confirming the starting privilege level before escalation — id msfadmin shows uid=1000 (non-root), and /etc/passwd / /etc/shadow permissions are reviewed.

Identify an Escalation Path

Vector: SUID-root Nmap 4.53 binary abused via its legacy interactive mode.
Why it works: The installed Nmap binary (version 4.53, dated 2008) is set with the SUID bit and owned by root. This old release still ships an `--interactive` mode that drops into an nmap console accepting `!<command>` syntax to shell out to the underlying OS. Because the nmap binary itself runs with the SUID-root permission, any command executed through that shell-out also runs with root's effective privileges — a textbook SUID misconfiguration (this interactive mode was later removed from Nmap specifically because of this abuse potential).

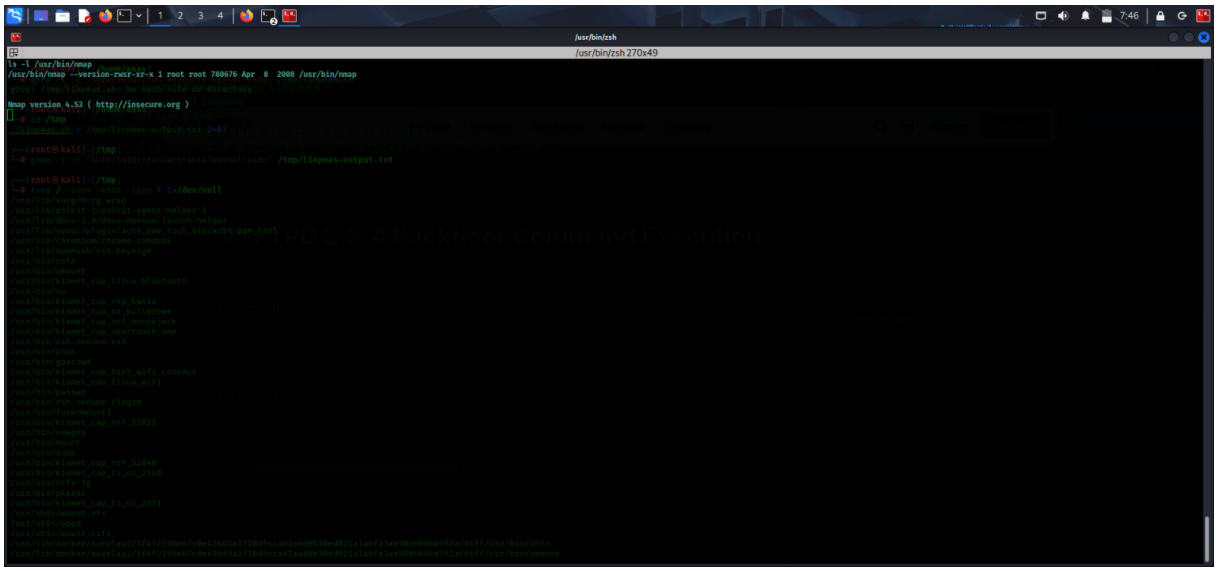


Figure 31. Identifying the vulnerable binary — ls -l /usr/bin/nmap shows the SUID bit set (rwsr-xr-x, owned by root) on Nmap version 4.53.

Execute the Escalation

Nmap's interactive mode was launched and used to run shell commands prefixed with "!", which execute with the binary's inherited root privileges rather than the calling user's.

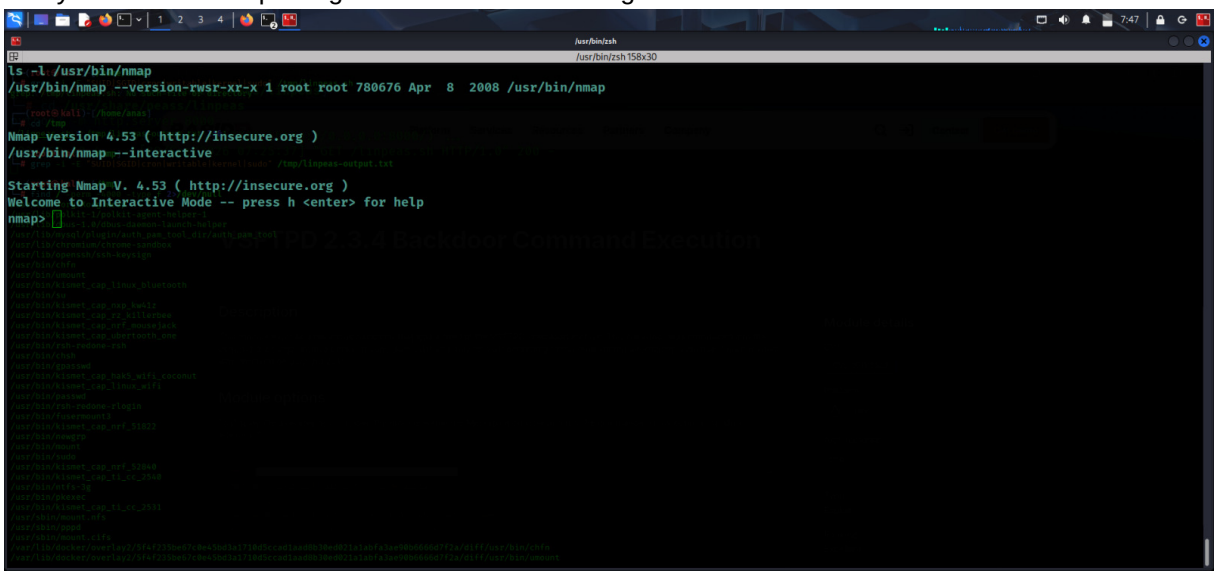


Figure 32. Launching Nmap's legacy interactive console (nmap --interactive).

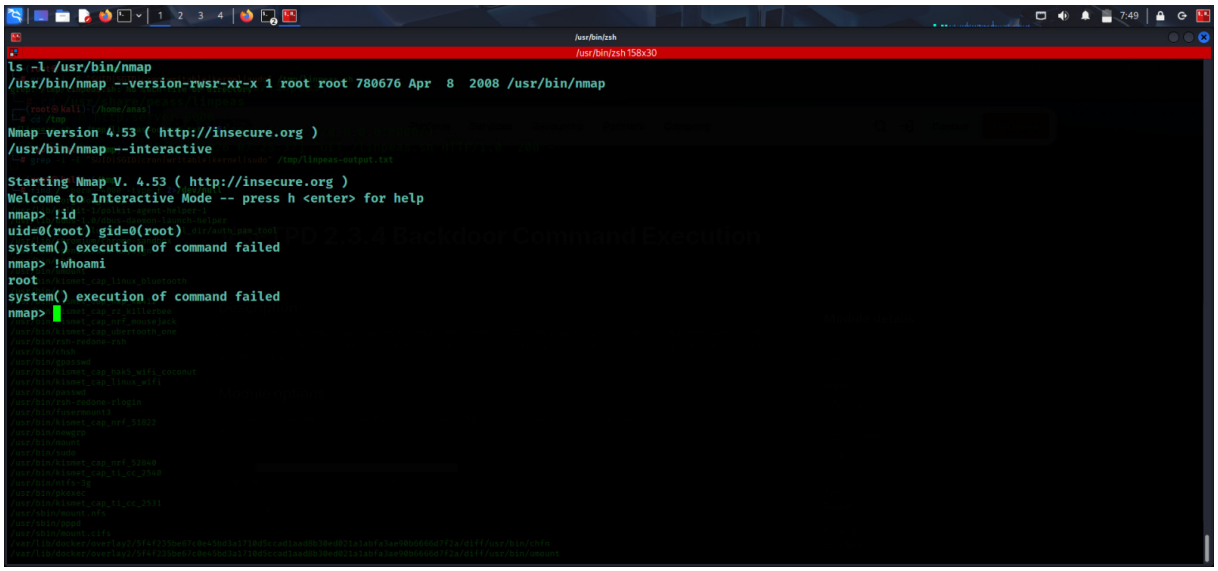


Figure 33. Running !id from inside the Nmap interactive console — output shows uid=0(root) gid=0(root), confirming successful privilege escalation via the SUID binary.

Confirming Elevated Privileges

The before/after contrast was captured directly: a plain `whoami` from the shell returns the low-privileged `msfadmin` account, while `!whoami` run through the SUID Nmap interactive console returns `root` — a clean demonstration of the full escalation chain from a standard user to root.

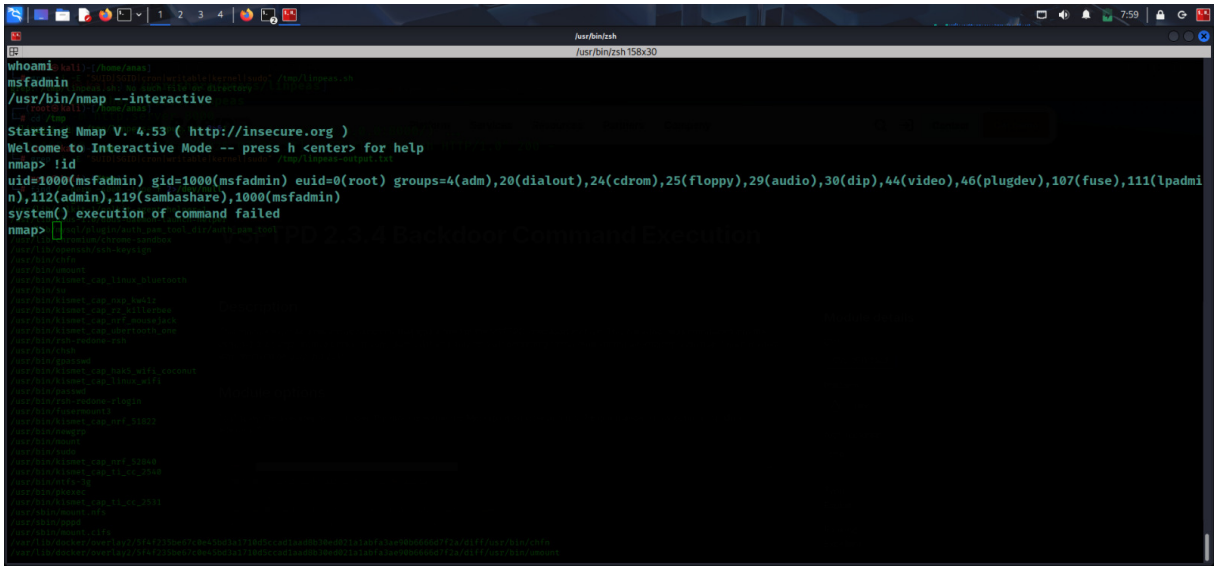


Figure 34. Before/after confirmation in a single view: whoami as the shell user returns 'msfadmin', while !whoami through the SUID Nmap interactive console returns 'root'.

5. Documentation

Initial Access Method (Recap from Week 4)

An initial low-privilege foothold was obtained in Week 4 against the same Metasploitable2 target using Metasploit, establishing the starting point for this week's escalation task.

Escalation Vectors Identified and Exploited

Vector 1 (network, direct-to-root): vsFTPd 2.3.4 Backdoor Command Execution (CVE-2011-2523) via `exploit/unix/ftp/vsftpd_234_backdoor`, targeting port 21/tcp.
Vector 2 (local, low-priv to root): SUID-root Nmap 4.53 binary abused through its legacy `--interactive` mode, allowing shell-out commands (`!id`, `!whoami`) to run with root's inherited effective privileges from the low-privileged msfadmin account.

Commands / Steps Used to Escalate

```
msf6 > search vsftpd 2.3.4
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.10.4
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.10.4:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.10.4:21 - USER: 331 Please specify the password.
[+] 192.168.10.4:21 - Backdoor service has been spawned, handling...
[+] 192.168.10.4:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.10.11:33295 -> 192.168.10.4:6200)
whoami
root
id
uid=0(root) gid=0(root)
hostname
metasploitable
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
    Vector 2: SUID Nmap local privilege escalation
find / -perm -4000 -type f 2>/dev/null

-rwsr-xr-x 1 root root 780676 Apr  8  2008 /usr/bin/nmap
whoami
msfadmin
/usr/bin/nmap --interactive
nmap> !id
uid=0(root) gid=0(root)
nmap> !whoami
root
```

Evidence

See Figures 1-9 for the vsftpd exploitation chain, Figures 10-27 for LinPEAS-based post-exploitation enumeration, and Figures 28-34 for the SUID Nmap local privilege escalation chain (enumeration, SUID discovery, exploitation, and before/after confirmation).

Impact: What Full System Compromise Means for the Organization

Root-level access to this host gives an attacker complete, unrestricted control of the system: the ability to read, modify, or delete any file; create or remove user accounts; install persistent backdoors or malware; pivot laterally to other hosts on the internal network (192.168.10.0/24); intercept or manipulate traffic for the other exposed services (SSH, SMTP, MySQL, PostgreSQL, Samba, NFS, etc.); and use the box as a foothold for further attacks. Because this vector requires no valid credentials, any attacker able to reach port 21 on this host can obtain the same outcome, making this one of the most severe classes of finding possible in a penetration test. Post-exploitation enumeration with LinPEAS further showed that this single compromise cascades into additional exposure: world-readable backup copies of /etc/shadow and /etc/passwd, legacy web application data, and even browser-cached login credentials (a stored twitter.com login) were all reachable once root was obtained. Most critically, plaintext SSH passwords for the msfadmin account were recoverable directly from log

files, and command-history files revealed that the MySQL root account had been created with no password at all — meaning credential exposure and lateral movement risk here extend well beyond just the initial vsftpd vulnerability, into fundamental account and logging hygiene across the whole host.

Mitigation: How This Escalation Path Should Be Closed

• Immediately remove/uninstall the compromised vsftpd 2.3.4 package and replace it with a current, verified-checksum version of vsftpd from an official, trusted repository.
• Verify the integrity of software downloads going forward using published checksums/GPG signatures to detect tampered archives before deployment.
• Disable and remove unused or legacy services entirely where not required (e.g. telnet, rsh/rexec, unauthenticated NFS) to reduce overall attack surface, as seen across this host's very large open port list.
• Apply a full OS and kernel update — the host is running a 2008-era kernel (2.6.24) with numerous known, unpatched vulnerabilities beyond just vsftpd.
• Segment lab/legacy systems away from production networks and place firewall rules in front of FTP/administrative services to restrict access to trusted hosts only.
• Implement network intrusion detection (IDS/IPS) to flag connections to non-standard high ports (such as 6200/tcp) that are indicative of backdoor shell activity.
• Remove world-readable permissions from backup files (shadow.bak, passwd.bak, group.bak, etc.) and store backups in access-controlled locations, ideally off-host or encrypted.
• Decommission unused/legacy web applications (e.g. old TikiWiki installs, DVWA, Mutillidae) from production-adjacent hosts, as these expand the exposed attack surface once a host is compromised.
• Avoid storing or caching credentials in browser profiles on shared/server systems, and rotate any credentials that may have been exposed via cached or history-file data.
• Enable a MySQL root password immediately and remove the passwordless root account flagged repeatedly in daemon.log; audit all database accounts for similarly weak or missing authentication.
• Rotate the msfadmin SSH password immediately, since it was recoverable in plaintext from /var/log/auth.log, and configure log handling so authentication attempts are not logged with recoverable password data.
• Clear or restrict access to shell and tool history files (.bash_history, .mysql_history) that can retain sensitive commands, and educate users against typing passwords directly on the command line.
• Remove the SUID bit from Nmap (chmod u-s /usr/bin/nmap) — Nmap does not need to run as root for standard scanning and should never be installed setuid; upgrade to a modern Nmap release, which no longer ships the abusable interactive mode.
• Conduct a full SUID/SGID binary audit across the host and strip the setuid/setgid bit from any binary that does not strictly require it, following the principle of least privilege.

Full Compromise Chain Summary

Stage	Result
Initial Access (Week 4)	Low-privilege foothold on Metasploitable2 via Metasploit
Enumeration	Nmap full port/service scan identified vsFTPd 2.3.4 on port 21; local SUID sweep identified a set
Vulnerability Identified	CVE-2011-2523 (vsftpd backdoor) and SUID Nmap interactive-mode command execution
Exploitation - Vector 1	exploit/unix/ftp/vsftpd_234_backdoor executed against 192.168.10.4 (direct root)
Exploitation - Vector 2	SUID Nmap 4.53 --interactive mode abused from msfadmin (uid=1000) to reach root
Result	Root access confirmed via two independent vectors; verified with whoami/id (uid=0) each time

Tools & Technologies

Kali Linux, Metasploit Framework, Nmap, LinPEAS, Exploit-DB/Rapid7 module reference, Metasploitable2 lab target.

GitHub Repository

https://github.com/Aans9988/Zyro-cyber-security-week-5.git

Scope Note

All activity described in this report was performed exclusively against the Zyroo internship lab target (Metasploitable2, an intentionally vulnerable practice VM) within an isolated lab network. No real, third-party, or public systems were accessed or tested.